CYBERSECURITY AVANZATA · LEZIONE 1 DI 8

Dalla falla al CVE

Che cosa succede tra il momento in cui qualcuno trova una vulnerabilità e il momento in cui il tuo PC si aggiorna. E come si misura quanto è grave.

5G TPSI

Ciclo di vita, CVE, CVSS, divulgazione coordinata, bug bounty

PER COMINCIARE

Scopri per caso che cambiando un numero nell'URL vedi il registro di un'altra classe. Che cosa fai?

SONDAGGIO

- **A** Niente: non sono affari miei
- **B** Lo dico subito al docente o alla segreteria, senza provare altro
- **C** Provo qualche altro numero per capire quanto è grave
- **D** Lo racconto ai compagni
- **E** Scrivo all'azienda che produce il registro

IL PERCORSO

La vita di una vulnerabilità

Scoperta

Un ricercatore, un fuzzer, un'AI o un criminale trova la falla.

Segnalazione

Al produttore, in privato.

Patch e avviso

Correzione, ID CVE, punteggio.

Aggiornamento

Chi usa il software installa la patch.

Zero-day: una falla che gli attaccanti sfruttano quando il produttore ha avuto "zero giorni" per correggerla.

Il tratto più pericoloso è spesso l'ultimo: la patch esiste, ma **nessuno la installa**.

PUZZLE

Metti in ordine: una falla scoperta da una ricercatrice, gestita bene

1. Il produttore conferma e chiede un ID CVE
2. Scrive al produttore all'indirizzo indicato nel suo security.txt
3. Trova un errore di memoria nel software di un router
4. La ricercatrice presenta la sua analisi a una conferenza
5. Viene pubblicato l'avviso con il CVE e il punteggio CVSS
6. Esce l'aggiornamento del firmware

UN NOME PER OGNI FALLA

CVE: Common Vulnerabilities and Exposures

CVE-2021-44228

- **2021**: l'anno in cui l'ID è stato assegnato o riservato
- **44228**: un numero progressivo, di 4 o più cifre
- Un ID = una falla, uguale in tutto il mondo: avvisi, antivirus e scanner parlano la stessa lingua

Chi fa che cosa

- **MITRE** gestisce il programma CVE, nato nel 1999
- **CNA**: le organizzazioni autorizzate ad assegnare gli ID (Microsoft, Google, Red Hat…)
- **NVD** e **EUVD**: database che arricchiscono i CVE con punteggi e prodotti colpiti

AL COMPUTER · 20 minuti

Leggi due falle famose nel database

1. Apri **nvd.nist.gov**, menu Vulnerabilities, e cerca **CVE-2021-44228**.
2. Annota: prodotto, data di pubblicazione, punteggio CVSS 3.x e il suo **vettore** (la stringa che inizia con `CVSS:3.1/`).
3. Ripeti con **CVE-2014-0160**.
4. Salva tutto in **cve-cognome.md**: per ciascuna, una riga su che cosa permetteva di fare.

Controllo: CVE-2021-44228 è Apache Log4j, punteggio **10.0** (Critical). CVE-2014-0160 è OpenSSL, la falla chiamata **Heartbleed**.

MISURARE LA GRAVITÀ

CVSS 3.1: un vettore, un numero da 0 a 10

Metrica	Domanda	Valori
AV	Da dove si attacca?	Network, Adjacent, Local, Physical
AC	Serve una situazione particolare?	Low, High
PR	Servono privilegi?	None, Low, High
UI	Serve un'azione della vittima?	None, Required
S	L'effetto esce dal componente colpito?	Unchanged, Changed
C · I · A	Quanto colpisce riservatezza, integrità, disponibilità?	High, Low, None

Fasce: **0.1–3.9** bassa · **4.0–6.9** media · **7.0–8.9** alta · **9.0–10.0** critica

QUIZ A TRABOCCHETTO

La tua azienda ha 200 falle aperte. Quali correggi per prime?

QUIZ

- **A** Quelle con il CVSS più alto, sempre
- **B** Quelle più vecchie
- **C** Quelle già sfruttate dagli attaccanti, sui sistemi esposti e importanti
- **D** Quelle che hanno un nome famoso, come Heartbleed

AL COMPUTER · 25 minuti

Dai tu il voto a tre falle

Apri il calcolatore ufficiale: **first.org/cvss/calculator/3.1**. Per ogni caso scegli le metriche e annota vettore e punteggio in **cvss-cognome.md**.

1. **Caso A**: chiunque su Internet, senza login e senza aiuto della vittima, esegue codice sul server e ne prende il controllo.
2. **Caso B**: un utente loggato cambia l'ID nell'URL e legge gli ordini degli altri clienti (l'IDOR della lezione 5).
3. **Caso C**: un link preparato fa eseguire uno script nel browser di chi lo apre (XSS riflesso).

Controllo: A = **9.8** critica · B = **6.5** media · C = **6.1** media. Se trovi altro, confronta il vettore con il compagno.

UNA PROMESSA DEL 1997

Tanti occhi, nessun bug?

> **Con abbastanza occhi, tutti i bug vengono a galla.**
>
> **Eric S. Raymond**, *La cattedrale e il bazaar* (1997), la chiama "legge di Linus" in onore di Linus Torvalds

Nel 2014 Heartbleed ha mostrato il limite: OpenSSL proteggeva mezzo web, ma lo mantenevano pochissime persone, quasi tutte volontarie.

QUIZ

Per quanto tempo il codice di Heartbleed è rimasto nelle versioni pubblicate di OpenSSL, prima di essere scoperto?

QUIZ

- **A** Poche ore: lo hanno notato subito
- **B** Circa una settimana
- **C** Circa tre mesi
- **D** Circa due anni

COME SI SEGNALA

Divulgazione coordinata, security.txt, bug bounty

Divulgazione coordinata

Segnali in privato, il produttore corregge, poi si pubblica insieme. Google Project Zero dà **90 giorni** di tempo.

security.txt

Un file in `/.well-known/security.txt` dice a chi scrivere. Standard **RFC 9116** (2022).

Bug bounty

Programmi che **autorizzano** i test su un perimetro preciso e pagano le falle trovate.

> Senza un'autorizzazione scritta, anche "solo per vedere" resta accesso abusivo. Il bug bounty è legale perché **le regole le scrive il proprietario**.

AL COMPUTER · 15 minuti

A chi scriveresti? Leggi i security.txt

1. Nel Prompt dei comandi:
   `curl -s https://www.google.com/.well-known/security.txt`
2. Ripeti con altri due siti a scelta (per esempio github.com e il sito di una banca). Se ricevi una pagina d'errore, il sito non ce l'ha.
3. In **cve-cognome.md** annota i campi `Contact`, `Expires` e, se ci sono, `Policy` e `Preferred-Languages`.
4. Scrivi il security.txt per l'app della vostra classe: 4 righe.

Controllo: ogni security.txt valido ha almeno un `Contact:` (e-mail o URL) e un `Expires:` con una data futura.

PUZZLE

Abbina ogni parola al suo significato

Zero-day	---	Catalogo delle falle con sfruttamento reale accertato
CNA	---	Sistemi che il proprietario autorizza a testare
KEV	---	Falla sfruttata prima che esista una correzione
EPSS	---	Probabilità che una falla venga sfruttata nei prossimi 30 giorni
Scope di un bug bounty	---	Organizzazione autorizzata ad assegnare gli ID CVE

AL COMPUTER · 30 minuti

Il calcolatore CVSS in Java

Scrivi **Cvss.java** con un metodo `double base(String vettore)` per i vettori con **S:U**.

```
iss  = 1 - (1-C)*(1-I)*(1-A)
imp  = 6.42 * iss
expl = 8.22 * AV * AC * PR * UI
base = imp <= 0 ? 0 : roundUp(min(imp+expl, 10))
```

AV N .85 A .62 L .55 P .2 · AC L .77 H .44 · PR N .85 L .62 H .27 · UI N .85 R .62 · C/I/A H .56 L .22 N 0

Controllo:
`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` stampa **9.8** e il vettore del caso B stampa **6.5**.

REGOLE NUOVE

Dal 2026 chi vende software deve segnalare

- **Cyber Resilience Act** (regolamento UE 2024): i prodotti con parti digitali vendute in Europa devono gestire le vulnerabilità per tutta la vita del prodotto
- Dall'11 settembre 2026 i produttori devono segnalare le falle **attivamente sfruttate** al CSIRT e all'ENISA
- Patch di sicurezza gratuite e un contatto per le segnalazioni diventano obblighi



CHI TROVA LE FALLE

Anche l'AI cerca vulnerabilità

I **fuzzer** inviano milioni di input casuali o malformati a un programma e guardano se si blocca: così si trovano molte falle di memoria.

OSS-Fuzz di Google prova da anni migliaia di progetti open source, ogni giorno, in automatico.



SFIDA A SQUADRE

Apri il lucchetto



- 1ª e 2ª cifra: la soglia CVSS da cui una falla è **critica**, senza virgola (x.0 → x0)
- 3ª e 4ª cifra: il punteggio del caso B del laboratorio, senza virgola

`codice`

BIGLIETTO D'USCITA

Completa prima di uscire

Una falla sfruttata prima che esista la patch si chiama _____.

Il punteggio di gravità da 0 a 10 si chiama _____.

Il file che dice a chi segnalare una falla è _____.

Log4Shell ha l'ID CVE-2021-_____.

Segnalare in privato e pubblicare insieme al produttore si chiama divulgazione _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Scoperta, segnalazione, patch, avviso, aggiornamento
- CVE: un nome unico per ogni falla
- CVSS: gravità tecnica da 0 a 10, letta dal vettore
- Priorità: sfruttata? grave? importante?
- Divulgazione coordinata, security.txt, bug bounty
- Senza autorizzazione non si prova nulla
- Cyber Resilience Act: segnalare diventa un obbligo
- Prossima lezione: XSS, CSRF e Content Security Policy

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.